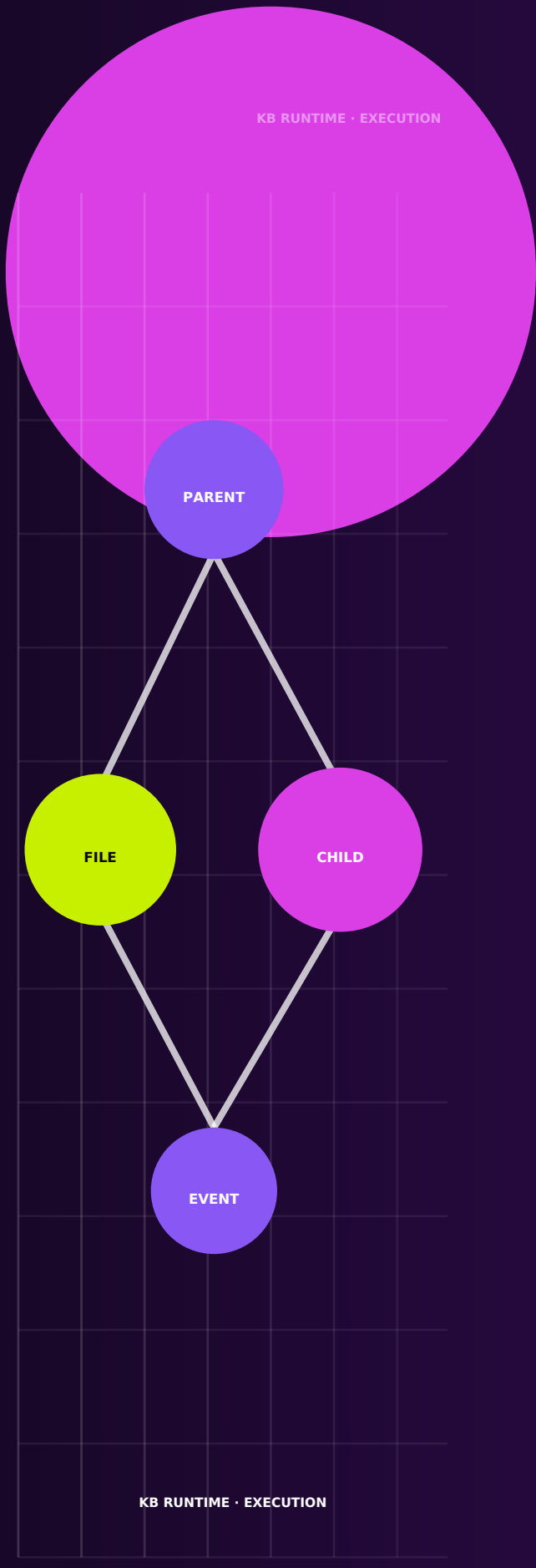
DETECTION THREAT LANDSCAPE

TEAMS-TO-AD CS INTRUSIONS - KB APPDATA RUNTIME EXECUTION

Defender XDR hunt for source-observed Bun or Java execution from KB-prefixed AppData Roaming paths



HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT TYPE
campaign

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Defender XDR

OPERATIONAL VALUE
8 / 10

01

Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

DECISION

Publish as a campaign-scoped hunting query, not an alert. Investigate matches as portable-runtime execution leads and require independent Teams, remote-support, discovery, identity or certificate evidence before associating a result with either documented intrusion.

SOURCE-CONFIRMED

- The source documents archive placement during a remote session, extraction into a newly created...
- The source-published hunt filters Bun or Java process identity, a .js or .java command-line operand, and...
- DeviceProcessEvents and every field used by the query are documented in the Microsoft...

ANALYST ASSESSMENT

- The combined runtime, script operand and path constraints are materially more specific than a...
- A match establishes only that the recorded process event met the published endpoint conditions; it...
- T1059.007 applies to the Bun JavaScript branch and T1036 applies to the source-observed...

DETECTION ASSUMPTIONS

- Microsoft Defender for Endpoint populates full FolderPath, ProcessCommandLine and proces...
- Authorized software deployment and developer workflows can be resolved to durable owners during...

KEY FINDINGS

FINDING 1

Microsoft investigated two human-operated intrusions that began with Teams help-desk impersonation and remote access, then staged portable runtimes and assessed AD CS. [C001]

FINDING 2

The reusable endpoint observable is Bun or Java executing a script from a KB-prefixed AppData Roaming directory; one variant used a renamed Bun binary whose version metadata retained the original filename. [C002]

FINDING 3

Microsoft published the exact DeviceProcessEvents conditions implemented here and explicitly positioned them as an investigation starting point requiring tenant validation and correlation. [C003]

EVIDENCE BOUNDARY

Microsoft did not disclose campaign dates, actor attribution or the exact prevalence of each runtime variant. Target-environment benign prevalence and ProcessVersionInfoOriginalFileName population are not measured. The endpoint event alone cannot establish the preceding Teams interaction or subsequent AD CS activity.

02

Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

TECHNICAL BACKGROUND

In two investigated intrusions, Microsoft observed help-desk impersonation through Teams followed by user-approved remote access. The operator placed an archive, extracted it under a newly created user-profile directory and launched attacker-controlled code with portable Python, Bun or Java runtimes before host discovery and AD CS assessment. Runtime choice varied, so this package retains only the source-published Bun/Java process observable: an executable identified by filename or Bun original-file metadata, a JavaScript or Java source operand and a KB-prefixed directory under AppData Roaming. [C001][C002][C003]

1

SOCIAL ENGINEERING

External Teams messages or calls impersonate support personnel and persuade a user to start remote control. Observable: Teams interaction and approved remote-support evidence; not queried by this package.

2

STAGING

An archive is transferred and extracted into a newly created KB-prefixed directory under the user profile. Observable: User-writable AppData Roaming path and surrounding file/process timeline.

3

EXECUTION

Bun or Java executes attacker-controlled JavaScript or Java source from the staged directory. Observable: DeviceProcessEvents with runtime identity, script operand and KB-prefixed FolderPath.

4

FOLLOW-ON CONTEXT

The staged components perform discovery and assess AD CS before the intrusion diverges into ESC1 or ESC8 paths. Observable: Discovery process lineage, LDAPS/SMB activity, Defender alerts, CA records and Kerberos evidence; enrichment only.

03

Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

PRIMARY PLATFORM

Microsoft Defender XDR. Return Bun or Java process events from numeric KB-prefixed AppData Roaming directories when the command line references JavaScript or Java source.

FIELD / TABLE	STATUS	PURPOSE
DeviceProcessEvents	**Required**	Microsoft Defender for Endpoint process-creation records for the source-published hunt.
Timestamp, DeviceId, DeviceName, FileName, FolderPath, ProcessCommandLine	**Required**	Time scope, stable device pivot, runtime identity, execution location and script operand.
ProcessVersionInfoOriginalFileName, SHA1, ProcessUniqueId, ReportId	**Required**	Identify renamed Bun, preserve file/process context and support event-level investigation.
InitiatingProcessFileName, InitiatingProcessCommandLine, AccountName	**Required**	Preserve parent and user context for ownership and timeline analysis.
CloudAppEvents, AlertInfo, AlertEvidence, CA/IIS and Kerberos records	**Enrichment**	Test the non-claim boundary by corroborating Teams, relay, certificate and authentication activity.

KNOWN VISIBILITY GAPS

No direct visibility into Teams interaction from this query No proof of script contents or malicious intent No CA issuance, PKINIT or DCSync evidence Mutable folder name and runtime choice Target-environment prevalence not measured

04

Primary Detection Logic

Native query, explicit condition evidence and match meaning.

KQL

```
// Rule: [T1059.007][T1036] Teams AD CS Intrusions - KB AppData Portable Runtime
// MITRE ATT&CK: T1059.007, T1036
// Classification: Hunting query
// Maturity: hunting
// Status: Untested implementation sketch
// Primary platform: Microsoft Defender XDR Advanced Hunting
// Required telemetry: Microsoft Defender for Endpoint DeviceProcessEvents
// Purpose: Hunt source-observed Bun or Java execution from KB-prefixed AppData paths.
// Logic: Runtime identity + .js/.java operand + numeric KB AppData Roaming path.
// A match proves: DeviceProcessEvents matched the published endpoint conditions.
// A match does not prove: Teams contact, malicious code, AD CS abuse, certificate use or attribution.
// Expected false positives: approved portable runtimes and developer or QA workflows.
// Coverage limits: mutable path/runtime; requires command line, path and version metadata.
// Evidence claims: C002, C003, C004, C005, C006, C007
// Validation status: Not executed; complete validation.md before promotion.

DeviceProcessEvents
| where Timestamp > ago(7d)
| where ProcessVersionInfoOriginalFileName =~ "bun.exe"
    or FileName in~ ("bun.exe", "java.exe", "javaw.exe")
| where ProcessCommandLine contains ".js"
    or ProcessCommandLine contains ".java"
| where FolderPath matches regex @"(?i)\\AppData\\Roaming\\KB[0-9]+\\"
| project
    Timestamp,
    DeviceId,
    DeviceName,
    AccountName,
    FileName,
    FolderPath,
    ProcessCommandLine,
    ProcessVersionInfoOriginalFileName,
    SHA1,
    ProcessUniqueId,
    InitiatingProcessFileName,
    InitiatingProcessCommandLine,
    ReportId
| order by Timestamp desc
```

WHAT A MATCH PROVES

Microsoft Defender for Endpoint recorded a process event matching the published runtime identity, script operand and KB-prefixed AppData path conditions.

WHAT IT DOES NOT PROVE

Teams impersonation, unauthorized remote access, malicious script content, AD CS assessment, ESC1 or ESC8 abuse, certificate issuance, PKINIT, DCSync, exfiltration or attribution.

MATURITY

Hunting query - Untested implementation sketch. Return Bun or Java process events from numeric KB-prefixed AppData Roaming directories when the command line references JavaScript or Java source.

05

Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

01

Preserve the raw DeviceProcessEvents row, query version, Timestamp, DeviceId, DeviceName, ProcessUniqueId and ReportId.

02

Confirm that FolderPath is the runtime image location and inspect ProcessVersionInfoOriginalFileName, FileName, SHA1 and file provenance without treating version metadata as signature evidence.

03

Recover the complete ProcessCommandLine and inspect the referenced .js or .java file, archive origin and creation timeline using authorized endpoint evidence.

04

Determine whether the runtime, KB-prefixed directory and account belong to approved software deployment, development or support activity.

05

Pivot to the initiating process and surrounding process/network timeline for discovery commands and LDAPS or SMB connections.

06

Escalate campaign linkage only when independent Teams, remote-support, Defender alert, CA issuance or Kerberos evidence corroborates the endpoint match.

DISPOSITION RULE

Escalate only when the evidence establishes the behavior described by the query. Teams impersonation, unauthorized remote access, malicious script content, AD CS assessment, ESC1 or ESC8 abuse, certificate issuance, PKINIT, DCSync, exfiltration or attribution.

06

False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

APPROVED PORTABLE JAVA OR BUN DEPLOYMENT IN A KB-NAMED APPLICATION DIRECTORY

Require package provenance, software owner, deployment record and expected script path or hash.

DEVELOPER OR QA EXECUTION OF JAVASCRIPT OR JAVA SOURCE FROM A USER-WRITABLE TEST DIRECTORY

Validate device role, user role, repository origin and repeatable development workflow.

VERSION METADATA OR COMMAND-LINE FIELD GAPS

Retain raw events and reject promotion if required branches cannot be evaluated consistently.

VALIDATION SEQUENCE

- Confirm DeviceProcessEvents coverage and population of every queried and projected field on representative Windows devices.
- In an authorized lab, run a benign portable Bun or Java runtime from AppData\Roaming\KB12345 with a harmless .js or .java operand and retain the raw process event.
- Run negative controls: the same runtime outside a KB-prefixed path, the KB path without a .js/.java operand, and an unrelated executable inside the KB path.
- Execute the query unchanged and verify that the controlled positive is returned while all three negative controls are excluded.
- Measure at least 30 days of historical prevalence, resolve every owner and document any legitimate software families before considering alert logic.

SUCCESS

The controlled positive returns one complete, explainable row; required fields are populated; negative controls do not match; and benign historical results can be separated with durable provenance.

REJECTION

Reject promotion when FolderPath or ProcessCommandLine is absent, process version metadata is unreliable for the Bun branch, negative controls match, or benign ownership remains unbounded.

PROMOTION GATE

Require retained positive and negative controls, field-completeness evidence, measured prevalence, durable allowlisting and an accountable owner before designing alert logic.

07

Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

CONCLUSION

The source-published process pattern is specific enough for a Defender XDR hunt and distinct from existing repository coverage, but it remains campaign-scoped and untested. Treat matches as endpoint execution leads; do not infer Teams delivery or AD CS compromise without independent evidence.

MITRE ATT&CK

T1059.007 / T1036

PRIMARY AND AUTHORITATIVE REFERENCES

S001 Microsoft Security Research - From help desk impersonation to AD CS abuse: Investigating ESC1 and ESC8 intrusion paths (2026-10-30)

hxxps://www[.]microsoft[.]com/en-us/security/blog/2026/10/30/help-desk-impersonation-ad-cs-abuse-investigating-esc1-esc8-intrusion-paths/

S002 Microsoft Learn - DeviceProcessEvents table in the advanced hunting schema (2026-08-07)

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table

S003 MITRE ATT&CK - T1059.007 - Command and Scripting Interpreter: JavaScript (2026-05-12)

hxxps://attack[.]mitre[.]org/techniques/T1059/007/

S004 MITRE ATT&CK - T1036 - Masquerading (2026-05-12)

hxxps://attack[.]mitre[.]org/techniques/T1036/

OPEN QUESTIONS

Microsoft did not disclose campaign dates, actor attribution or the exact prevalence of each runtime variant. Target-environment benign prevalence and ProcessVersionInfoOriginalFileName population are not measured. The endpoint event alone cannot establish the preceding Teams interaction or subsequent AD CS activity.

DOCUMENT CONTROL

Schema 2.0 | Layout 2.0 | Maturity hunting | Confidence Medium | No customer data | Evidence ledger required